02_INSTRUCTOR_ANSWER_KEY

Pintop | 2026 Training

Password Handling & Token-Session Design - instructor expected outcomes and response prompts

Reference source: `codebase/app/Http/Controllers/PayTrackAuthController.php`

Original lesson steps

1. **Show a password being hashed. Then say: “You never store the password itself. You store a slow, one-way hash, unique per user.”**
2. **Compare a login attempt. Then say: “You do not decrypt; you hash the attempt and compare the result.”**
3. **Issue a login token or session. Then say: “The server remembers the user across requests, because HTTP itself forgets.”**
4. **Test the edges. Then say: “Wrong password, expired token, logged-out token. This is where authentication really lives.”**

Oral questions and example answers

- **Ask:** "Why hash passwords instead of encrypting them?" **Expected answer:** hashing is one-way, so even a stolen database does not reveal the passwords.
- **Ask:** "Why make the hash deliberately slow?" **Expected answer:** slowness makes guessing passwords impractical while barely affecting a real login.
- **Ask:** "What is the difference between a session and a token?" **Expected answer:** a session keeps state on the server; a token is signed and self-contained.

Assessing student evidence

Accept work when students can open the correct source, explain one meaningful code statement, demonstrate a valid local check, describe one error case and save their work in a disposable copy. Do not mark a blocked environment as passing. Do not mark raw copied code without explanation as complete.

Teacher troubleshooting

When a student is stuck, ask: "Show me the exact line you changed. What was the expected result? Which command did you actually run? What did it return?" Check the working directory and dependencies before changing code.